Research 2026-10-21: workspace UI patterns, invitation email, Gemini Deep Research, file hand-over

Method: three sourced web-research passes. "UNVERIFIED" = not confirmed from a fetched page. Numbers for hover pills are our own choice, not copied from any product.

A. Breadcrumbs, lists, sidebar, search, menus

Breadcrumbs

- W3C APG: no special keyboard model; a `nav` landmark with `aria-label`, `ol > li > a`; last item `aria-current="page"` (https://www.w3.org/WAI/ARIA/apg/patterns/breadcrumb/).
- Carbon: never wrap; when short show first + last two, middle in an overflow menu; phone: overflow + one crumb (https://carbondesignsystem.com/components/breadcrumb/usage/). Atlassian: collapsed items = ellipsis labelled "Show more breadcrumbs"; apps with a sidebar may drop the top level (https://atlassian.design/components/breadcrumbs/usage). NN/g: show location, not history; current page last and unlinked (https://www.nngroup.com/articles/breadcrumbs/).
- Notion shows sibling pages when hovering a crumb (third-party source only). Supabase moved to one organization at a time with an org picker in the header and an `/organizations` page (https://supabase.com/changelog/33670-upcoming-breaking-change-to-dashboard-navigation). Linear/GitHub/Figma/Drive crumb behaviour: UNVERIFIED.
- Rules adopted: crumb items are link + small chevron button that opens a sibling list (click, not hover only); middle crumbs hidden on narrow screens; link height >= 24px.

Org / project list pages

- Vercel: grid/list toggle saved per user, sort by activity/name, find bar, "Add New" (https://vercel.com/docs/projects/managing-projects). Delete = typed project name; "Pause" offered as a softer option.
- Supabase roles Owner/Administrator/Developer/Read-only; invites expire in 24h, can be revoked and resent; an org needs at least one owner (https://supabase.com/docs/guides/platform/access-control). GitHub org delete: typed name, irreversible warning, alternatives offered (https://docs.github.com/en/organizations/managing-organization-settings/deleting-an-organization-account).
- NN/g confirmations: name the item and consequences, label buttons by outcome, prefer undo, typed confirmation only for rare high-stakes actions (https://www.nngroup.com/articles/confirmation-dialog/). Carbon empty states: first use / no results / error; title, body, action (https://carbondesignsystem.com/patterns/empty-states-pattern/).
- Rules adopted: one toolbar (search, sort, view toggle persisted, one primary create button); three empty-state kinds; invitations always reachable (header button on org and project pages, command palette, and the pending-invite entry); danger zone at the bottom of Settings; soft delete first with restore, typed name for permanent delete.

Sidebar: Notion sections Recents/Favorites/Teamspaces, each collapsible, Trash/Help pinned at the bottom (https://www.notion.com/help/sidebar). Linear: hide rare items behind "More", counts only for actionable things (https://linear.app/changelog/2024-12-18-personalized-sidebar). Rule: sidebar = navigation inside the current project; account, org settings and members live elsewhere; badges only for actionable counts; collapsible sections with remembered state.

Search / palette: GitHub prefixes `> # @ / ?`, scope chip (https://docs.github.com/en/get-started/accessibility/github-command-palette); Linear/Notion show recents on empty query and have filters (https://linear.app/docs/search, https://www.notion.com/help/search); Vercel palette is desktop-only so a mobile search button is needed. APG list-autocomplete combobox (focus stays on input, `aria-activedescendant`). Rule: ONE search entry in the header; groups Actions / Navigate / Documents; prefixes; filter chips; recents.

Account menu / header actions: Supabase keeps the account menu top-right; Claude/Notion/Linear keep it in the sidebar. Claude's exact item list UNVERIFIED. Rule: menu width 220-280px (not the sidebar width), rows 28-32px; items: name+email, settings, help, shortcuts, release notes, backup, sign out. Header right: Search, notifications bell (review inbox), pin, copy link, overflow "…" with page actions.

Density: Primer ActionList `inset` variant; WCAG 2.2 target size >= 24x24 (https://www.w3.org/WAI/WCAG22/Understanding/target-size-minimum.html). One rule set: row height 30px, radius 7px, padding 4px 8px, inset from container edges, focus by outline.

Dropdowns: `appearance: base-select` — Chrome/Edge 135+, Safari 27 (Sep 2026), Firefox behind a flag, so not Baseline (https://web.dev/blog/web-platform-09-2026). We use our own select-only combobox (APG pattern: https://www.w3.org/WAI/ARIA/apg/patterns/combobox/examples/combobox-select-only/) so look and behaviour are identical everywhere.

B. Invitation email (research, no code yet)

- Supabase built-in SMTP: 2 messages/hour and only to addresses of your Supabase org team, all plans (https://supabase.com/docs/guides/auth/auth-smtp). Not usable.
- Resend free: 100/day but `onboarding@resend.dev` only sends to your own account address; a verified domain is needed (https://resend.com/docs/knowledge-base/403-error-resend-dev-domain). Brevo (300/day) cannot authenticate gmail.com senders; Postmark rejects Gmail sign-ups; SendGrid has no permanent free plan; SES sandbox = verified recipients only.
- Gmail SMTP with an app password: works for any recipient, mail is signed by Google (SPF/DKIM/DMARC aligned), about 500/day (third-party figure). Needs 2-Step Verification + a 16-character app password. Supabase Edge Functions block outgoing ports 25 and 587 (https://supabase.com/docs/guides/functions/limits); 465 UNVERIFIED. A Vercel Node function with nodemailer on 465 is the planned path (UNTESTED until credentials exist).
- Google Apps Script web app (`MailApp.sendEmail`): HTTPS only, no app password; consumer cap 100 recipients/day; URL is public so a shared secret is mandatory.
- Domain route later: ~10 USD/year + Resend free tier gives a branded sender.
- Animation support (caniemail, data updated 2026-09-16): CSS keyframes only in Apple Mail (macOS/iOS), Samsung, Thunderbird, HEY, Fastmail; NOT Gmail, any Outlook, Proton. Animated GIF plays in Gmail/Apple/Yahoo/Outlook.com but not Outlook for Windows (shows a frame). Base64 images are blocked in Gmail, inline SVG and video unsupported, AMP needs a registered non-Gmail sender. Gmail clips HTML above ~102KB; `<style>` only in `<head>`, 16KB.
- Technique adopted: static inline-styled 600px table layout (works everywhere) + hosted animated GIF hero (Gmail etc.) + optional head `<style>` keyframes for Apple Mail/iOS/Samsung + dark-mode overrides + bulletproof button + plain-text part + alt text. Base styles stay in the finished state so clients that strip animation still show the complete design.
- Security: scanners (Microsoft Safe Links) open links, so the link must only load a harmless page; the token is consumed by the "Accept" click (already how our `#/join/<token>` works). Never put the token in preview text. Rate-limit invitations; escape inviter/org names; set Reply-To to the inviter.

- Copy pattern: subject "{Inviter} invited you to join {App}", one headline, one button, plain URL under it, "expires in N days", "If you weren't expecting this, ignore it — nothing happens until you click". GitHub and Vercel use 7-day expiry (https://docs.github.com/en/organizations/managing-membership-in-your-organization/inviting-users-to-join-your-organization).
- Owner action unavoidable: a sender credential (Gmail app password, or Apps Script deploy) must be created by the owner; it goes into the Vercel environment settings, never into chat or code.

C. Gemini Deep Research (Oct 2026)

- "Argon" = Gemini 4 Argon, Google's flagship reasoning model, thinking levels low/medium/high (https://ai.google.dev/gemini-api/docs/models/gemini-4-argon, updated 2026-10-14). "Argon High" as a Deep Research mode/UI label is UNVERIFIED — most likely Argon at the High thinking level; the owner should send a screenshot of the picker.
- Plans (https://gemini.google/subscriptions/): AI Plus 4.99, AI Pro 19.99, AI Ultra from 99.99 USD/month. Limits are compute-based, refresh every 5 hours with a weekly cap (https://support.google.com/gemini/answer/17004136); exact Deep Research counts and parallel-run limits UNVERIFIED.
- Files: "Add Files"; up to 10 files per prompt, 100MB each, ZIP up to 10 files (https://support.google.com/gemini/answer/14903178). Whether .md/.txt are accepted by Deep Research UNVERIFIED -> convert to PDF or Google Docs. Google Search on by default; Drive/Gmail optional. The plan can be edited before "Start research"; export to Docs.
- Prompt practice (Google API doc + guides): state objective, scope, time frame, structure of the output; name preferred source types; ask for inline citations with URLs and for "unknown" instead of estimates; say which attached file is authoritative; edit the plan before starting; split big topics into 3-6 runs and synthesise. Template in docs/11.

D. Why files from the cloud session often do not open

- Cloud sessions have a view-only file pane; edits only inside the working directory. Official docs do not describe a download action (https://code.claude.com/docs/en/desktop.md). Our session rules say the app opens only files inside the primary working directory (/home/user/gf), the scratchpad and memory directories.
- Earlier notes were written to /home/user (outside /home/user/gf) -> the likely reason they did not open.
- Reliable routes: files inside /home/user/gf committed and pushed (GitHub link), private Artifact pages (.html/.md, 16 MiB max), Claude Docs, teleport. Plan: put every deliverable in /home/user/gf/docs, push to GitHub, and publish a private Artifact for reading.

Research 2026-10-21: planning layer (master file > phases > steps), decisions, document health

Pages fetched 2026-10-21. DESIGN = design inference by the researcher, no authoritative standard. UNVERIFIED = not confirmed. Feeds master plan phase 4.

What other tools do

- Notion: sub-items by parent relation; deleting a parent deletes children; dependencies are an opt-in feature [N1]. Linear: initiatives group projects; statuses Proposed/Planned/Active/Completed/Canceled; health is a manual on/at-risk/off-track update [L1]; project graph counts unestimated issues as 1 point, in-progress at 1/4 in forecasts, cancelled issues lower scope [L3]. GitHub: sub-issues up to 8 levels and 100 children; Markdown tasklist blocks retired [G1][G2]; projects have typed fields, table/board/roadmap [G3].
- Obsidian Tasks: status = one character, each with a type TODO/IN_PROGRESS/ON_HOLD/DONE/CANCELLED/NON_TASK [O1]; Dataview `completed` only for `x`, `fullyCompleted` also needs all subtasks [O2]. Org-mode: `[/]`/`[%]` count direct children by default; parent box derives from children [OM1].
- Shape Up: hill charts track scopes, not tasks; percent complete misleads because tasks keep appearing; appetite = fixed time, variable scope; pitch = Problem, Appetite, Solution, Rabbit holes, No-gos [B1][B2].
- Takeaway: every tool separates a typed row (status, dates, parent) from free text. Use rows as the source of truth and render Markdown from them; import/export checkbox Markdown through a status-character map. We need states beyond done/not done: blocked, cancelled, deferred.

Recommended schema (DESIGN; reuses docs, doc_revisions and the AI change sets)

```
plan_nodes: id, project_id, ref (step:4-3, unique per project), kind (phase|step; sub-
step = step with a step parent),
  parent_id fk on delete RESTRICT, position text COLLATE "C" (fractional key)
unique(parent_id, position),
  title, notes_md, doc_id null, status (todo|doing|done|blocked|cancelled|deferred),
weight int>=0 default 1,
  owner, due, started_at, completed_at, rev, created_at, updated_at; check parent<>id;
depth <= 4 by trigger
plan_edges(from_id, to_id, type blocked_by|relates)  -- trigger rejects cycles
decisions: id, project_id, ref D-0012 (sequential, never reused), title, status
(proposed|accepted|rejected|deprecated|superseded),
  superseded_by, decided_on, decision_makers[], context_md, drivers_md, options jsonb,
outcome_md, consequences_md, confirmation_md, review_by, rev
decision_links(decision_id, target_kind node|doc|decision, target_id, rel
drives|blocks|motivated_by|supersedes)
docs add: owner, review_every_days, last_reviewed_at, reviewed_rev, verified_until
doc_links(from_doc, to_ref, resolved, checked_at)  -- rebuilt on save
```

- Hierarchy: adjacency list + `WITH RECURSIVE` (with CYCLE and a depth limit) [PG1]; a closure table or ltree only if queries get slow [CT1][CT2]; ltree availability on Supabase free UNVERIFIED.
- Ordering: fractional keys as text with COLLATE "C"; keys are case-sensitive and must not be sorted with localeCompare; one owner needs only the unique constraint plus a retry [FI1][FI2].
- RLS: inherit from project_id via the existing private.can_read_project / can_edit_project; wrap auth.uid() in (select …), index project_id and parent_id, name the role in every policy, keep definer helpers in the private

schema with search_path " [S1].

- AI proposals: the AI never writes plan tables. It submits ops {set_status|move|insert|retitle|edit_notes, node_id, base_rev, value} into the Review inbox; accept applies only if rev = base_rev, otherwise the op is stale. AI may only create decisions as `proposed`. Check marks are never auto-applied (a check mark is a claim of completion). Moves are validated for cycles and depth before display.

Progress rules (DESIGN)

1. Only leaf steps count; parents are never stored. Phase % = sum(weight of done leaves) / sum(weight of countable leaves), over all descendants; show n/m beside the %.
2. Cancelled and deferred leaves leave the denominator (Linear lowers scope on cancel [L3]); do not group CANCELLED with done as Obsidian Tasks does [O1].
3. Blocked stays in the denominator as not done; show a red count and the reason from blocked_by.
4. `doing` counts 0 in the headline; optional toggle "in progress at 25%" [L3].
5. Weights default 1; small integers only; show the weight when siblings differ.
6. An empty container shows "no steps", never 0% or 100%; a phase is `done` only when every countable leaf is done; round down so 99.6% never shows 100%.
7. Marking a parent done while children are open: warn and offer "mark all children done"; never cascade silently.
8. Show scope change: store a baseline denominator when a phase starts and show "+N steps added" [B1]; optional uncertain/known flag (cheap hill chart).
9. Compute in a SQL view or RPC, never in a stored column.

Decision record

MADR 4.0.0 (2024-09-17) with optional YAML front matter status/date/decision-makers/consulted/informed [M1]; Y-statement as the one-line summary [Y1]. Lifecycle: proposed > accepted > deprecated | superseded by another record | rejected; never delete or renumber; the old record points to its replacement [NY1]; accepted records are immutable except status and supersession (our rule).

```
---
id: D-0012
status: proposed   # proposed|accepted|rejected|deprecated|superseded by D-00NN
date: 2026-10-21
decision-makers: [owner]
review-by: 2027-01-21
drives: [step:4-3]
---
# Short title naming problem and solution
In the context of <..>, facing <..>, we decided for <..> and neglected <..>, to achieve
<..>, accepting that <..>.
## Context and Problem Statement / Decision Drivers / Considered Options / Decision
Outcome / Consequences / Confirmation / Pros and Cons / More Information
```

Linking: `[[D-0012]]` in a step or document creates a decision_links row on save; a step blocked_by an open/proposed decision shows "waiting on D-0012"; accepting a decision offers to unblock linked steps; superseding shows a badge on old links; review-by feeds the stale list.

Document health, ranked for a solo owner

1. Owner + last_reviewed_at + review_every_days + "verified" state (Notion verified pages: owner, until-date, expiry notice [N2]); an AI-accepted edit does NOT renew the review; reviewed_rev flips the page to "changed since verified" after any later edit; default window about 90 days for fast-changing docs [MB1].
2. Stale/blocked dashboard (overdue review, review window passed, blocked steps, proposed decisions) via pg_cron nightly (Supabase suggests at most 8 concurrent jobs, each under 10 minutes [S2]).
3. In-app link check on save (doc_links; broken links, orphan pages, duplicate titles, steps pointing to a deleted decision); no network needed.
4. markdownlint on save, warnings only (MD001, MD024, MD051, MD052/53); has a browser build [ML1].
5. lychee in CI for external links on exported Markdown, scheduled, not on every push; `--offline`, `--cache`, GITHUB_TOKEN to avoid rate limits [LY1].
6. Vale: CLI only (not browser/Edge); low value for one author [V1]. 7. Drift detection from code: skip.

Templates (DESIGN)

Software: Shape (problem, appetite, rabbit holes, no-gos) > Build > Test > Release > Operate; seed decisions stack/hosting/auth. Research: Question and scope > Sources and method > Collection > Analysis > Writing > Review; step type "claim to verify" with a source link. Course: Outcomes > Syllabus > Content production (module sub-steps, weight by hours) > Practice and assessment > Launch > Revise. Trip: Dates and budget decision > Transport > Stay > Itinerary by day > Bookings (deadlines) > Pre-departure checklist (+ ICS feed). "This master plan": import our `[x]/[~]/[ ]/[?]` Markdown via a status map (~ doing, ? blocked "waiting on owner").

Mistakes to avoid

Stored progress on parents; counting cancelled/deferred/empty phases; blocked treated as done or invisible; AI-accepted edits counted as reviews; parsing the plan only from Markdown text (no stable ids); closure table / ltree too early; integer positions or locale-sorted fractional keys; AI changing checks, decisions or moves without base_rev; cascade delete (use on delete restrict + Trash); editing accepted decisions in place; one global review window; lint that blocks saving; percent alone (also show blocked count, scope added, next step).

Not verified

GFM nested checkbox behaviour; Supabase ltree availability; exact Notion rollup and GitHub sub-issue progress formulas.

Sources

[N1] notion.com/help/tasks-and-dependencies · [N2] notion.com/help/wikis-and-verified-pages · [L1] linear.app/docs/initiatives · [L3] linear.app/docs/project-graph · [G1] docs.github.com/en/issues/tracking-your-work-with-issues/using-issues/adding-sub-issues · [G2] docs.github.com/en/get-started/writing-on-github/working-with-advanced-formatting/about-tasklists · [G3] docs.github.com/en/issues/planning-and-tracking-with-projects/learning-about-projects/about-projects · [O1] publish.obsidian.md/tasks/Getting+Started/Statuses · [O2] blacksmithgu.github.io/obsidian-dataview/annotation/metadata-tasks/ · [OM1] orgmode.org/manual/Checkboxes.html · [B1] basecamp.com/shapeup/3.4-chapter-12 · [B2] basecamp.com/shapeup/1.2-chapter-03 · [M1] adr.github.io/madr/ · [Y1] ozimmer.ch/practices/2020/04/27/ArchitectureDecisionMaking.html · [NY1] cognitect.com/blog/2011/11/15/documenting-architecture-decisions · [PG1] postgresql.org/docs/current/queries-with.html · [CT1] percona.com/?p=2688 · [CT2] dev.to/dowerdev (secondary) · [FI1] github.com/rocicorp/fractional-indexing · [FI2] figma.com/blog/realtime-editing-of-ordered-sequences/ · [S1]

supabase.com/docs/guides/database/postgres/row-level-security · [S2] supabase.com/docs/guides/cron · [MB1] metabase.com/metrics/documentation-freshness (vendor page) · [ML1] github.com/DavidAnson/markdownlint · [LY1] github.com/lycheeverse/lychee · [V1] docs.vale.sh

Research 2026-10-21: MCP security, tokens, Supabase OAuth, AI-edit review, invitee data (feeds phase 6, docs/04)

Tags: VERIFIED = first-party page read; SNIPPET = search excerpt only; UNVERIFIED = not confirmed. Not legal advice.

Bottom line

docs/04 is right in direction but outdated in four places: Supabase OAuth is now verified as a public beta; Client ID Metadata Documents (CIMD) are missing; there is no per-client matrix (most clients can send an Authorization header, so path tokens are only needed for the Gemini app); the Supabase OAuth risk that tokens carry full user privileges is not mentioned. Phase 6 order is wrong: verifying clients (6.6) must come BEFORE OAuth (6.5). The path token is acceptable only as a labelled, short-lived, read-only fallback.

MCP status (VERIFIED, modelcontextprotocol.io/specification/2026-07-28/...)

Latest revision 2026-07-28: stateless (Mcp-Session-Id and initialize removed, `server/discover` added), tasks moved to an extension, multi round-trip `input_required`, `tools/list` results carry `ttlMs` and `cacheScope`, Dynamic Client Registration (DCR) deprecated in favour of CIMD, clients must validate `iss` (RFC 9207), HTTP+SSE deprecated. Authorization: the server is an OAuth 2.1 resource server with Protected Resource Metadata (RFC 9728); clients send RFC 8707 `resource`; servers validate audience and never forward tokens; tokens go in `Authorization: Bearer` and MUST NOT be in the query string; 401 with `WWW-Authenticate` carrying `resource_metadata`. Which clients implement 2026-07-28: UNVERIFIED.

Client	Header token	OAuth	Notes
Claude Code	`--header "Authorization: Bearer …"`, `headersHelper`	`/mcp` login, CIMD, DCR, `--client-id`	VERIFIED code.claude.com/docs/en/mcp. A rejected configured header does not fall back to OAuth. Redirect bug v2.1.229 (127.0.0.1 vs localhost), fixed in v2.1.231. No OAuth in `claude -p`.
claude.ai / Desktop / mobile connectors	"Request headers" beta, limited orgs	CIMD or DCR, redirect https://claude.ai/api/mcp/auth_callback	VERIFIED claude.com/docs/connectors/building/authentication. Uses CIMD only if metadata advertises `client_id_metadata_document_supported: true` and `none` auth; else DCR; needs a real 401 with `resource_metadata`; first `authorization_servers` entry only; 10 s / 30 s timeouts; docs say never accept tokens in the URL.
Cursor	`headers` with `${env:VAR}`	static client id or DCR	VERIFIED cursor.com/docs/context/mcp
VS Code	`headers` with `${input:…}`	`oauth.clientId`	VERIFIED
Gemini CLI	`headers`	401 discovery, DCR, `iss` check	VERIFIED geminicli.com/docs/tools/mcp-server/; page says replaced by "Antigravity CLI" for unpaid/Google One users on 2026-06-18
ChatGPT developer mode	not confirmed	OAuth (CIMD/DCR), none, mixed	SNIPPET; plan eligibility conflicts
Gemini app	UNVERIFIED	UNVERIFIED	Google help (support.google.com/gemini/answer/17209137): add a custom app by MCP server URL on web, US, English, personal account, 18+, Keep Activity on; if no DCR enter credentials manually; writes need confirmation. Plan requirement unclear.

Attacks and mitigations

Official page /specification/2026-07-28/basic/security_best_practices (VERIFIED): confused deputy, token passthrough, SSRF, state hijack, OAuth URL injection, mix-up, localhost redirect impersonation, CIMD trust, scope minimization. We are not a third-party proxy, but with Supabase as authorization server our consent page must name the client and redirect URI, have CSRF protection, anti-framing headers and exact redirect matching; enabling CIMD means we fetch client URLs (SSRF). Tool poisoning/rug pull: practitioner write-ups only (SNIPPET: Willison 2025-07-06, Zuplo, Invariant); mitigation = pin tool definitions by hash on the client. Our real risk is OUR documents as the injection channel (lethal trifecta). Missing in docs/04: exfiltration through rendering — Markdown in proposals can carry remote images/links; if the Review inbox auto-loads them, injected text can leak content before a human accepts.

Tokens

GitHub format (VERIFIED github.blog): type prefix + underscore + 32-bit CRC32 checksum in the last 6 characters, base62; prefix alone cuts false positives to ~0.5%. Partner secret-scanning programme needs a public HTTPS verifier endpoint: too heavy for a solo project; use the format and a gitleaks rule. OWASP: credentials must not be in URLs (logs). SHA-256 of a high-entropy token is adequate (judgement). Path token: Supabase edge logs and Vercel logs contain it (retention unconfirmed) -> only read-only, 24 h to 7 d, low daily limit, one per client, revoked on rotation.

Supabase Auth OAuth 2.1 server (VERIFIED supabase.com/docs/guides/auth/oauth-server/..., changelog 38022)

Public beta (GA target Q4 2025 passed; no GA notice found — check live docs). Available on all plans; signed-in users count to MAU. You supply the consent page ("Authorization Path"). PKCE S256 required; DCR off by default; no CIMD documented. Phase 1 has no scopes: tokens carry full user privileges and rely on RLS, so a leaked MCP token is a normal user JWT that works against PostgREST. `aud` changes only via a custom access token hook; RFC 8707 `resource` not mentioned. Documented defences: RESTRICTIVE RLS on `auth.jwt()->>'client_id' IS NOT NULL`, and an `aud` hook that rejects unknown clients. Access tokens 3600 s, refresh rotates; HS256 default (RS256/ES256 recommended).

Human review of AI edits

Sourced: Google Docs suggestions (colour-tracked, nothing changes until accepted, accept one by one or all, owner emailed — support.google.com/docs/answer/6033474); Claude Code manual vs accept-edits mode (code.claude.com/docs/en/security); Claude connectors tool-level Blocked/Always allow; ChatGPT write actions confirm by default (SNIPPET). Cursor, Copilot, Notion AI, Grammarly, Outline pages could not be fetched (omitted). Over-trust research is thin (SNIPPET arXiv 2412.18531): reviewers dismiss issues assuming the bot would flag them; polished output lowers scepticism; usual mitigation = deterministic gate. Audit trails (SNIPPET, vendor blogs): hash chain per row, optional HMAC, signed checkpoints, triggers blocking UPDATE/DELETE, chain head anchored outside the database; the owner is also DB admin so anchoring matters more than the chain.

Invitee data

Could not fetch GDPR Art. 17 text (one-month deadline is from memory: UNVERIFIED). EDPB summary of an Irish case: emailing non-users without consent/legitimate interest was not justified; "compare and forget" accepted (platform contact imports, not exactly our case). Whether GDPR applies to a solo owner's personal use:

UNVERIFIED. Practical minimum: purge or hash invitee email after accept/expiry; per-person export and delete; log retention period; no tokens or IPs in logs.

Ranked changes

1 (S) run client verification first (Claude Code, Cursor, claude.ai, Gemini app), then make `header` the default token kind and `path` the exception. 2 (S) sanitise the Review inbox: no remote images, link targets as text, diffs as plain text. 3 (S) token format `gfk_…` + CRC32 base62 checksum, show last 4 characters, gitleaks rule in CI. 4 (M) docs/04 items 1-2: two token kinds, rotation with overlap, path tokens 24 h by default. 5 (M) per-token tool and document allow-lists; static tool descriptions; expose a hash of the tool list. 6 (M) OAuth stage: enable Supabase OAuth server with DCR, write consent page (client name, exact redirect URI, CSRF, anti-framing), RESTRICTIVE RLS for `client_id IS NOT NULL`, custom access token hook setting/checking `aud` and rejecting unknown clients, Edge Function returns 401 + `resource_metadata` and validates aud/client_id/iss, keep manual tokens as fallback, test with Claude Code and claude.ai. 7 (M) review friction: reason required for high-risk accepts, no bulk accept for them, auto-accept only a narrow class. 8 (M) invitee data purge/export/delete, log retention. 9 (M) hash-chained audit log + weekly head emailed to an external mailbox. 10 (M) anomaly alerts + auto-pause. 11 (L) support spec 2026-07-28 once the clients you use adopt it. Defer: two-person approval, GitHub partner programme. Risk: building the OAuth stage on a beta feature with full-privilege tokens and no RESTRICTIVE RLS would widen exposure beyond today's read-only path tokens.

Sources (fetched 2026-10-21)

modelcontextprotocol.io/specification/2026-07-28/{basic/authorization, changelog, basic/security_best_practices} · claude.com/docs/connectors/{building/authentication, custom/add-unlisted} · code.claude.com/docs/en/{mcp, security} · cursor.com/docs/context/mcp · code.visualstudio.com/docs/agents/reference/mcp-configuration · geminicli.com/docs/tools/mcp-server/ · supabase.com/docs/guides/auth/oauth-server{,/getting-started,/mcp-authentication,/token-security} · supabase.com/changelog/38022-oauth-2-1-server-capabilities-for-supabase-auth · github.blog/engineering/platform-security/behind-githubs-new-authentication-token-formats/ · docs.github.com/en/code-security/secret-scanning/secret-scanning-partnership-program/secret-scanning-partner-program · cheatsheetseries.owasp.org/cheatsheets/REST_Security_Cheat_Sheet.html · support.google.com/docs/answer/6033474 · SNIPPET: simonwillison.net/2025/Jul/06/supabase-mcp-lethal-trifecta/, zuplo.com/blog/remote-mcp-server-rug-pull/, arxiv.org/pdf/2412.18531, edpb.europa.eu (ie_2022-04), appmaster.io/blog/tamper-evident-audit-trails-postgresql

NOTE 2026-10-21 (owner rule D11, spend nothing): the paid parts of this report (Anthropic API, paid Gemini, any credit or deposit) are DROPPED. Free-only plan: docs/11 phase 7 and prompt Z1 in docs/12. The retrieval design, quote-verification algorithm, evaluation set, injection rules and cost-guard ideas below still apply.

Research 2026-10-21: ask-the-docs (cheapest safe build) — feeds phase 7

(1P) = first-party page fetched. Everything else third-party or UNVERIFIED. The fetch tool summarises pages with a small model, so confirm any number you rely on on the page itself.

Bottom line

Primary: Anthropic API, Claude Haiku 5.5 with the Citations feature, prepaid with a spend cap, about $0.0006 per question (~$0.60 per 1,000). Fallback: Gemini API paid tier (prepay $5 minimum), Flash-Lite, quote-then-verify JSON. Retrieval: Postgres full-text search by headings; add pgvector only if the 40-question test shows weak recall. Do NOT rotate five free OpenRouter accounts (breaks terms, pointless). Do NOT send private docs to a free tier that trains on data (conflicts with D1). NotebookLM (now "Gemini Notebook") cannot be called from the app: personal reader only.

Providers (as of 2026-10-21)

- Anthropic (1P platform.claude.com/docs/en/about-claude/pricing, /api/rate-limits, /build-with-claude/citations): Haiku 5.5 $0.10 in / $0.50 out per MTok up to 100k-token prompts, $0.50/$2.50 above; cache reads $0.01/MTok; Haiku 4.5 $1/$5; Sonnet 5.5 $2/$10; start tier $500/month cap, you can set lower; no free tier; inputs/outputs not used for training by default (privacy.claude.com/en/articles/7996868); citations work on all active models, ZDR-eligible, `cited_text` not counted as output; citations and structured outputs cannot be combined (HTTP 400). Minimum deposit UNVERIFIED.
- Gemini API (1P ai.google.dev/gemini-api/docs/{rate-limits (2026-10-15), pricing (2026-10-19), billing, terms}): free-tier numbers not published (AI Studio shows per project); free tier content may be used to improve products and read by humans; paid not used for training; EEA users require paid services; 3.1 Flash-Lite $0.25/$1.50, 3.5 Flash-Lite $0.30/$2.50 per MTok; prepay minimum $5.
- OpenRouter (1P openrouter.ai/docs/api-reference/limits, /terms): `:free` models 20 req/min and 50/day under $10 of credit, 1,000/day at $10+; extra accounts/keys do not change limits; terms 7(3) bans multiple accounts to circumvent limits; 6.1 some models may train on inputs. -> one account with $10 at most.
- Groq: free-plan figures unclear (gpt-oss-120b 30 req/min, 1K/day, 200K tokens/day, per organization). Cerebras: free trial 5 req/min, 1M tokens/day, "no permanently free tier". Mistral: official limits not found (404). Cloudflare Workers AI: 10,000 neurons/day free, bge-small embeddings $0.02/M tokens (1P, 2026-10-20). Hugging Face: free users no credits. GitHub Models: retired 2026-07-30 (1P). OpenAI: gpt-5-nano $0.05/$0.40 per MTok, text-embedding-3-small $0.02/MTok, no quote API.
- plan file docs/06-API-PLAN.md still says "5 keys rotation": remove it.

Retrieval

A few hundred pages ≈ 0.3-0.6M tokens: do not put everything in the prompt (above 100k tokens Haiku 5.5 costs 5x per token). FTS: stored generated tsvector, GIN index, websearch_to_tsquery, ts_rank in an RPC; heading weight A, body B (1P supabase.com/docs/guides/database/full-text-search). Chunk by h2/h3, keep heading path, split chunks over ~600 tokens at paragraph breaks, store page id and character offsets; top 6 chunks. Embeddings only if recall@6 < ~90%: Supabase hybrid search with RRF (1P supabase.com/docs/guides/ai/hybrid-search), gte-small 384 dims in an Edge Function (docs from 2024, recheck), Gemini Embedding 2 $0.20/M tokens, OpenAI 3-small $0.02/M;

indexing 0.5M tokens costs $0.01-0.10. Gemini File Search tool (managed, 1 GB free store, Markdown supported) ties us to Google with coarse citations: skip.

Verbatim-quote verification (run on every answer)

Option A (primary): send each retrieved chunk as a `document` block with `citations: {enabled: true}`; API returns `cited_text` + location indexes. Option B (any model): JSON `{claims:[{text, chunk_id, quote}]}` or `{refuse:true}`. 1 Normalise quote and chunk: Unicode NFC, collapse whitespace, unify curly/straight quotes and dashes, strip Markdown emphasis markers. 2 Pass only if the normalised quote is a contiguous substring of the named chunk, and the chunk was one of those retrieved. 3 Reject quotes under 6 or over 80 words. 4 Display text from our database using the matched offsets, never the model's copy; link to the heading anchor. 5 If any claim fails retry once naming the failing quote; then show "No verified answer" with retrieved headings as links. 6 Substring proves existence, not support: use the golden set and an optional judge pass.

Evaluation (~$0.03 per run of 40 on Haiku 5.5)

24 single-page facts (8 with numbers/exact strings), 6 two-page questions, 4 paraphrases with little keyword overlap, 6 unanswerable, 2 targeting a planted injection page; hand-written gold page and gold quote each. Metrics: recall@6; quote validity 100%; answer correctness ≥ 90% (owner judged); groundedness (LLM judge "does the quote entail the claim?" + human check of 10); correct refusals 6/6; false refusals ≤ 10%. Re-run after every model, prompt or chunking change; keep history. (RAG Triad per OWASP LLM01:2025.)

Prompt injection

Documents are attacker-controlled (collaborators, AI tools). The Q&A function has no tools (one model call, no web, no writes, no MCP; text only). Never render model output as HTML/Markdown links or images; show plain text and database quotes; link only to our heading anchors. Delimit retrieved text in tagged blocks and say it is data. Retrieve under the caller's identity with RLS. Reuse the phase 6.7 scanner; keep injection items in the golden set. Residual risk: a planted real quote still passes substring: show the source page next to every answer.

Keys and cost guard (1P supabase.com/docs/guides/functions/secrets)

Key only as an Edge Function secret (dashboard or `supabase secrets set`, `Deno.env.get`); names cannot start with `SUPABASE_`; one key for this app in its own provider workspace with its own cap. Never in the bundle (`VITE_`), git, chat, plain DB column, localStorage, MCP token path, logs. Free plan: 500,000 function calls/month, 2 s CPU, 150 s wall clock. Keep JWT verification on; re-check membership in SQL; table `ai_usage(user_id, day, requests, est_cost_micro)` with atomic upsert RPC; ~30 questions/day per user, ~300/day global, kill switch; cap question 500 chars, context ~6k tokens, max_tokens ~600; cache by hash(normalised question, project, content version); hard monthly cap in the provider console (e.g. $5; billing data can lag ~10 min); browser never chooses model or provider.

Gemini app side

NotebookLM / Gemini Notebook: free 50 sources per notebook, each ≤ 500,000 words or 200 MB (1P support.google.com/notebooklm/answer/16215270); compute-based limits (AI Pro 4x, refresh 5 h, weekly cap) (1P support.google.com/gemininotebook/answer/17670842); read-only sharing; no MCP/API mentioned; merge several hundred pages into ≤ 50 files. Gemini app custom MCP app: see docs/14. Gems are removed from personal accounts from November 2026, replaced by skills (1P support.google.com/gemini/answer/15146780): do not build on Gems.

Recommended plan and monthly cost

7.1 answer Q8: no rotation, no free tier for private docs; deposit the minimum on Anthropic, cap $5, own workspace. 7.2 key via Supabase secret dialog. 7.3 FTS chunks + one Edge Function (auth, rate limit, retrieve, Haiku 5.5 with Citations, substring check). 7.4 build the 40-question set first. Later: Gemini paid fallback behind the same function; pgvector only on recall failure. Cost: 1,000 questions ≈ $0.60; 5,000 ≈ $3; total ≈ $1-3/month + one-time ~$5 deposit; with 100k-token contexts ~10x more (the 6k cap prevents it). Risks: a real quote can still mislead or be planted; price jump above 100k-token prompts; free-tier numbers unstable (Gemini, Mistral, Groq UNVERIFIED); free-tier privacy; Gemini custom apps US/English only; EEA needs paid Gemini; model names "Haiku 5.5/Sonnet 5.5" come from the live pricing page, no model was called (latency and citation quality untested).

Research 2026-10-21: Supabase Free / Vercel Hobby / GitHub Actions limits and ops additions (feeds phases 3 and 9)

First-party pages fetched 2026-10-21 unless marked UNV (unverified or third-party). Not checked: the live project's advisors/extension list, third-party keep-alive claims, branching on Free.

Limits

Area	Limit	Source
Supabase projects	2 active; paused ones do not count	supabase.com/pricing
DB	500 MB, shared CPU, 500 MB RAM	pricing
Egress	5 GB + 5 GB cached	pricing
Storage	1 GB total, max file 50 MB (cannot be raised on Free)	/docs/guides/storage/uploads/file-limits
Auth MAU	50,000	pricing
Realtime	200 concurrent connections, 2M messages/month, 100 msg/s, 100 channels per connection, broadcast payload 256 KB, Postgres-change payload 1,024 KB	/docs/guides/realtime/limits
Edge Functions	500k invocations/month; 256 MB; 2 s CPU per request; 150 s wall clock; 100 functions; bundle 20 MB CLI / 5 MB dashboard; outgoing ports 25 and 587 blocked; 100 secrets	/docs/guides/functions/limits
Auth email	built-in SMTP 2/hour and ONLY to project team members; custom SMTP starts at 30/hour	/docs/guides/auth/auth-smtp
Auth rate limits	sign-in 30 per 5 min per IP; refresh 150 per 5 min	/auth/rate-limits
Inactivity pause	after 7 days of "insufficient user database activity"; warning email ~1 week before; restore window 1 year (2024 changelog said 90 days)	/docs/guides/platform/free-project-pausing
Backups	none on Free (export with `supabase db dump`); Pro 7 daily backups; PITR ~100 USD/month, Pro+	/docs/guides/platform/backups
Logs	1 day Free, 7 days Pro	pricing
pg_cron	recommended ≤ 8 concurrent jobs, each ≤ 10 min; Free availability not stated (UNV)	/docs/guides/cron
DB connection	direct connection is IPv6 only; GitHub Actions is IPv4 only -> use the Supavisor session pooler (port 5432); IPv4 add-on Pro only ~4 USD/month	/docs/guides/database/connecting-to-postgres
MFA	TOTP free on all plans; phone MFA paid; leaked-password protection Pro+ (this corrects our earlier note "no MFA on free" — confirm in the dashboard)	search of supabase.com; /auth/password-security
Vercel Hobby functions	300 s max; 2 GB / 1 vCPU; 1M invocations, 4 h active CPU, 360 GB-hrs/month	vercel.com/docs/limits (2026-09-16)
Vercel Hobby transfer/builds	100 GB fast data transfer; 100 deployments/day; 1 concurrent build; runtime logs kept 1 hour	same
Vercel Hobby cron	once per day, up to 59 min jitter	/docs/cron-jobs/usage-and-pricing
Vercel Hobby commercial use	non-commercial personal use only (ads, sales, paid hosting count as commercial)	/docs/limits/fair-use-guidelines

Area	Limit	Source
Vercel Hobby, new 2026-09-16	keeps only the 3 latest production deployments past 30 days; 10 GB deployment storage	vercel.com/changelog/hobby-projects-now-retain-fewer-deployments-to-free-up-storage
GitHub Actions	private repo 2,000 min/month, 500 MB artifacts; public repo standard runners free; scheduled workflows in public repos are disabled after 60 days without repo activity	docs.github.com billing
Pro: Supabase from 25 USD/month (8 GB DB, 250 GB egress, 100 GB storage, 7-day backups, no pausing, leaked-password protection); Vercel Pro 20 USD/month (1 TB transfer, per-minute cron, commercial use).		

What breaks first

1. **Supabase Data API grants change on 2026-10-30** (supabase.com/changelog/45329): new `public` tables are no longer auto-granted to anon/authenticated/service_role; existing tables keep grants; a migration that creates a table without explicit GRANT fails with 42501. Affects `share_links`, `plan_nodes`, `decisions`, `ai_usage` and every future table. (Our 0016 only created functions, which carry explicit grants.)
2. Backups on Free: nothing exists unless we build it; dumps from GitHub Actions must use the session pooler string.
3. Pause risk: our only protection is in-DB pg_cron, which may not count as user activity (undocumented). `/auth/v1/health` does not touch Postgres (UNV).
4. Invitations to real people fail until custom SMTP or an HTTP email API / Gmail function is on (done: /api/invite on Vercel).
5. Realtime is fine for solo + a few people if each tab uses one channel. 6. The 2 s CPU limit hurts heavy work in the MCP function. The 500 MB DB is the likeliest long-term cap (audit logs, versions, embeddings). 7. Hobby is non-commercial. 8. Legacy anon/service_role JWT keys are planned for retirement by end of 2026: migrate to `sb_publishable_` / `sb_secret_` keys (/docs/guides/getting-started/migrating-to-new-api-keys); pg_net and Database Webhooks then need the secret key in the `apikey` header.

Keep the project alive

A real read through PostgREST from OUTSIDE the DB once a day: a daily Vercel cron hitting a function that reads a tiny table, plus a GitHub Actions schedule as second source (note: scheduled workflows in a public repo self-disable after 60 days without activity). Route the pause warning email to a mailbox you read. Pro is the real fix if the project becomes important.

Ranked additions

Phase 3: (S) GRANT in the same migration as RLS for every new table, nothing to `anon` on private tables, matrix assertion `has_table_privilege('anon', t, 'select')` is false; (S) revoke execute on every security definer function from anon/public (lints 0028/0029), definer functions outside exposed schemas with `set search_path = ''`; (S) policies use `(select auth.uid())`, `to authenticated`, index every policy column, no `user_metadata` (lint 0015), `security_invoker = true` on views (0010); (S) run get_advisors after each migration and fail CI on ERROR level; (M) pgTAP (`supabase/tests/database`, `supabase test db`) next to the DO-block matrix (which tests the live project); (S) share_links: hash, constant-time compare, rate-limited lookup RPC, expiry in the RPC, `noindex` + `Referrer-Policy: no-referrer` on that route only; (S) D1 enforced by RLS and RPC, not just the UI. Phase 9: (M) nightly backup via Actions with `supabase db dump --db-url <session-pooler>` (roles, schema, data `--use-copy`), encrypt with `age` (public key in repo, private offline), upload as artifact/release asset not git commits, fail if dump is empty/schema-only; storage bucket separately; (M) weekly restore drill into a throwaway

Postgres service container + row-count checks; (S) keep-alive as above; (S) headers in vercel.json: CSP (`default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; connect-src 'self' https://plbvgcnyfclillatpowc.supabase.co wss://plbvgcnyfclillatpowc.supabase.co; font-src 'self'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'` — NOTE our app loads Google Fonts, so font/style hosts must be added; start with Report-Only), Referrer-Policy strict-origin-when-cross-origin (no-referrer on share routes), nosniff, Permissions-Policy camera/microphone/geolocation off, HSTS; `frame-ancestors` only works as an HTTP header; (S) Dependabot (npm + github-actions weekly), `npm audit --omit=dev` + osv-scanner, gitleaks-action; (S) deploy Edge Functions and migrations from CI with a scoped access token (`supabase/setup-cli@v1`, `db push --dry-run` first); (M) axe in CI via @axe-core/playwright with wcag2a/aa and 21a/aa tags; visual regression only with baselines generated on the CI OS/browser; Playwright artifacts: retention 7 days, traces only on failure (500 MB quota); (S) monitoring: free uptime ping of the MCP address; log errors to a small table (Vercel runtime logs last 1 hour on Hobby); (M) search: tsvector generated column + GIN + websearch_to_tsquery; unaccent/pg_trgm availability UNV (check Extensions list); (L) pgvector: gte-small is English-only and truncates at 512 tokens; a few hundred pages need no index or HNSW; 384 floats ≈ 1.5 KB per chunk.

Corrections to our assumptions

Context pack said "no MFA on free": TOTP is free (phone MFA paid). 9.6 "cron stops": the pause criterion is user DB activity; do not rely on in-DB cron as keep-alive. Nightly dump from the direct host fails from Actions (IPv6): use the pooler. Vercel Hobby cron is once a day. Check phase 11 for commercial intent (Hobby is non-commercial). Email from an Edge Function: ports 25/587 blocked; use an HTTPS API (our Gmail path runs on Vercel, not the Edge Function). Phase 3.4 needs grant checks (`has_table_privilege`, `has_function_privilege`) as well as RLS behaviour.

Research 2026-10-21: editor, collaboration, diff, offline/PWA, Markdown, import/export (feeds phases 5 and 8)

Versions/dates from the npm registry fetched 2026-10-21 [N]; sizes from Bundlephobia whole-entry min+gzip [B] (approximate, overstate tree-shaken use). GitHub issue counts mostly UNVERIFIED (API blocked). "mine" = researcher's reasoning.

Editors

Editor	Version (last release)	License	Gzip	Markdown round-trip	Health
CodeMirror 6 (view 6.43.15, merge 6.12.3, lang-markdown 6.5.2)	2026-10-19	MIT	view ~80 KB	lossless (the text is the document)	very active; `@uiw/react-codemirror` 4.25.12 supports react >=17
Tiptap 3 (core/react 3.32.0)	2026-10-13	MIT	react ~9, starter-kit ~106, markdown ~19 KB	`@tiptap/markdown` (MarkedJS) is an "early release", no comments, table cells one child node [tiptap.dev/docs/editor/markdown]	very active
Lexical 0.52.0	2026-09-28	MIT	core ~63 KB	transformer based, no loss statement	pre-1.0
BlockNote 0.56.0	2026-10-14	MPL-2.0	~188 KB	docs call Markdown import "lossy"	active
Milkdown 7.22.3 / Plate (platejs 53.3.18) / MDXEditor 4.3.3	Oct 2026	MIT	not measured	fidelity UNVERIFIED	active
Novel 1.0.2	2025-01-18	Apache-2.0	–	Tiptap based	looks stale
Recommendation: source-faithful Markdown with live preview = **CodeMirror 6** (no round-trip risk; AI diffs, 3-way merges and revisions all work on Markdown text; `@codemirror/merge` gives per-hunk accept/reject from the same dependency; preview via `react-markdown` 10.1.0; inline live preview is later polish). Trade-off: not WYSIWYG. Block editing = **Tiptap 3 + @tiptap/markdown, optional, after CM6**, gated: on open, parse then serialize and compare with the stored text; if different, open source mode only. Avoid BlockNote (lossy, biggest, MPL-2.0), Novel (stale), Lexical (pre-1.0).					

Collaboration

Yjs 13.6.33 (~28 KB), Hocuspocus 4.7.1 (needs a long-lived server; Vercel WebSocket public beta since 2026-06-22, Hobby availability UNVERIFIED), `@supabase-labs/y-supabase` 0.1.0 (pre-1.0; avoid), Liveblocks (hosted; free plan 500 monthly active rooms, 3 members, non-commercial), Automerge 3.5.0 (~1.6 MB gz: cut). Supabase Realtime without CRDT: 200 concurrent connections, 100 msg/s, 20 presence msg/s, 256 KB broadcast (docs/16) — enough for presence. A CRDT is worth it only if 2+ people routinely type in the same document at once with live cursors or long offline merges (mine); a Yjs document is binary, so a Markdown projection must be kept in sync for search, llms.txt and AI edits (and the AI would have to edit through Yjs). **Recommendation 5.2:** `version` column,

save with `update … where version = base`, on conflict 3-way merge with `node-diff3` 3.2.1 (~2 KB), show remaining conflicts as a diff; Presence only for a soft "X is editing" banner; nothing important in Presence.

Diff and suggestions

`@codemirror/merge` `unifiedMergeView({original})` with `acceptChunk`, `rejectChunk`, `getChunks`; `mergeControls` render function since 6.11.0: best fit for per-hunk accept in the Review inbox (baseline = current doc, editor holds AI text). `diff` (jsdiff) 9.0.0 (~8 KB) for headless hunks (`structuredPatch`, apply selected hunks) and revision compare. diff-match-patch stale (2020): skip. prosemirror-changeset only with ProseMirror: skip. Store suggestions as hunks (base version, range, replacement), not editor marks.

Offline / PWA

`vite-plugin-pwa` 2.0.0 (2026-10-03; breaking changes not read), workbox 7.4.1. Quotas per origin, Chrome up to 60% of disk, Safari 17+ ~60% (MDN storage quotas; webkit.org/blog/14403). Eviction removes an origin's data at once; `navigator.storage.persist()` asks for exemption. Safari deletes script-writable storage after 7 days without interaction; WebKit says home-screen apps have their own counter (webkit.org/blog/10218) but developers report contradictions (bugs.webkit.org 237350): test on your iPhone. Android: assume Chromium rules. Private docs (mine): precache app shell only; do not runtime-cache API responses in Cache Storage; keep an allow-listed set (pinned docs) in IndexedDB via Dexie 4.4.6; offline read-only first (offline editing needs an outbox + merge: a second project). Sign-out: delete IndexedDB databases, `caches.keys()`+`caches.delete()`, unregister the service worker, optionally `Clear-Site-Data: "storage"` (MDN: unregisters service workers; `"cache"` behaviour must be tested). Free plan pause means keep your own JSON backup.

Markdown

CommonMark 0.31.2 (2024-01-28); GFM spec 0.29 (2019), looks stale. Front matter is not standard: `remark-frontmatter` 5.0.0 + `yaml` 2.9.1. unified 11.0.5, remark-parse 11.0.0, remark-gfm 4.0.1, rehype-sanitize 6.0.0, react-markdown 10.1.0: mature, slow-moving. Math: remark-math 6.0.0 + rehype-katex 7.0.1 + katex 0.19.0 (~77 KB, lazy). Mermaid 12.2.0 (~174 KB, lazy-load when a document has a mermaid fence; default `securityLevel: 'strict'`; `sandbox` beta). Sanitization: rehype-sanitize default schema follows GitHub's; place it after the last unsafe step; it prefixes ids/names with `user-content-` (breaks in-page anchors: our "stable block anchors" need a fix-up); for math sanitize first with a schema allowing `math-inline`/`math-display`, then katex; never `allowDangerousHtml` without sanitizing. `[[kind:slug]]` needs a small micromark/remark plugin.

Import / export

`fflate` 0.8.3 (~12 KB) preferred over `jszip` 3.10.2 (~28 KB; CVE-2022-48285 path traversal fixed in 3.8.0). Untrusted zip checklist (SonarSource RSPEC-5042; implementation ours): reject `..`, absolute paths, backslashes, drive letters, NUL; cap entry count, total and per-entry uncompressed size; check compression ratio (legit ≈ 1-3); enforce limits while decompressing; do not trust extensions; run in a Web Worker with a timeout; fflate's built-in limits unknown, add ours. `.docx`: `mammoth` 1.13.0 performs no sanitisation, can emit `javascript:` links, crafted files can burn CPU/memory, Markdown output deprecated: docx -> HTML (mammoth) -> sanitize -> Markdown (`turndown` 7.2.4). Notion export: zip of CSV + Markdown, callouts exported as HTML (notion.com/help/export-your-content); third-party (updated Feb 2026): 32-hex ID suffix per file, images in subfolders, internal links reportedly not preserved (UNVERIFIED): write a resolver. Obsidian: `[[Note]]`, `[[Note|alias]]`, `[[Note#Heading]]`, `[[Note#^block]]`, `![[embed]]`; on export use standard Markdown links with URL-encoded paths (obsidian.md/help/links).

Stack for phases 5 and 8

1 CodeMirror 6 + @codemirror/merge + react-markdown preview. 2 version-column save + node-diff3 + Presence banner. 3 jsdiff for revision compare/headless hunks. 4 fflate + mammoth + turndown in a Worker with sanitizing and caps. 5 vite-plugin-pwa precaching the shell only + IndexedDB pin list. Cut/defer: CRDT/Hocuspocus/Liveblocks/Automerge, Tiptap block editor (later, gated), offline editing and background sync, inline live-preview decorations, semantic search, Mermaid sandbox, Notion link-graph reconstruction, rich suggestion marks, PDF export (use print CSS). Mistakes to avoid: WYSIWYG that rewrites Markdown on save; caching authenticated API responses in the service worker; not wiping caches/IndexedDB at sign-out; sanitize order mistakes (rehype-raw, KaTeX); unzipping without caps; mammoth Markdown output; relying on y-supabase or Novel; trusting a Safari quota number; assuming a home-screen app is safe from eviction. Not checked: Milkdown/Plate/MDXEditor round-trip; Safari 7-day rule and Clear-Site-Data on real devices; Vercel Hobby WebSockets; jsdiff v9 release notes. Sources: registry.npmjs.org/; bundlephobia.com/api/size; codemirror.net/docs/changelog/ and /docs/ref/#merge; tiptap.dev/docs/editor/markdown; lexical.dev/docs/packages/lexical-markdown; blocknotejs.org/docs/features/import/markdown; github.com/{Milkdown/milkdown, steven-tey/novel, mdx-editor/editor, supabase-community/y-supabase}; liveblocks.io/docs/pricing/plans/free; vercel.com/changelog/websocket-support-is-now-in-public-beta; developer.mozilla.org Storage_quotas_and_eviction_criteria, Clear-Site-Data; webkit.org/blog/{10218,14403}; spec.commonmark.org; mermaid.js.org/config/usage.html; github.com/rehypejs/rehype-sanitize; github.com/mwilliamson/mammoth.js; notion.com/help/export-your-content; obsidian.md/help/links; vulert.com/vuln-db/CVE-2022-48285; rules.sonarsource.com RSPEC-5042.

Research 2026-10-21: document-workspace benchmark vs our master plan

Legend: Y yes, P partial, N no/not found, ? UNVERIFIED (no first-party page reached), $ paid, EE enterprise. A "?" is a gap in evidence, not proof of absence. Universal basics (tree, move, trash, Markdown export) omitted.

Capability matrix (products: Notion, Outline, Docmost, AFFiNE, AppFlowy, BookStack, Confluence, GitBook, Slab, Obsidian, Anytype)

- Verified/owner/expiry: Notion Y$, Outline N, Docmost EE, Confluence P, GitBook P, Slab Y on the free plan, Obsidian N. (N2 notion.com/help/wikis-and-verified-pages; S1 slab.com/pricing; S2 help.slab.com/en/articles/4136379-post-verification)
- Per-page permission override: Notion Y, Outline Y, Docmost Y$ (Business), AppFlowy Y (v0.9.4), BookStack Y, GitBook roles only.
- Guests: Notion Y (10 free), Outline $, Slab Y (3/user paid), Anytype Y. Comments + mentions: Outline Y (read-only users can comment), Docmost P (resolve EE), GitBook Y (change-request review).
- Version history: Notion 7 days free, Docmost free + compare (v0.96), Slab 90 days free, Obsidian 1 month/12 months paid. Public share: Notion Y (expiry), Outline Y, Docmost Y free, GitBook Y (private links paid), Obsidian Publish.
- API/webhooks: Notion, Outline, BookStack (webhooks since v21.12), Confluence, GitBook, Slab Y; Docmost API EE. MCP: Notion, Outline, GitBook Y; Docmost EE.
- Audit log: Enterprise in Notion, Slab, Docmost, GitBook; BookStack Y (admin). Page analytics: Notion basic free, GitBook all plans, Slab 30 days free, Confluence Premium+ (1-year lookback, privacy mode).
- Notifications inbox: Notion, Docmost (v0.71), GitBook, Slab. Favorites/recents: Notion, Docmost (v0.80). Search: Notion split keyword vs AI on 2026-09-02; Docmost filters v0.96, vector EE; Slab facets (verified/expired).
- AI Q&A: Notion $20 Business, Outline $, Docmost EE, AppFlowy $8.9 add-on, GitBook Essential+, Slab Business+. SSO/SCIM mostly paid tiers. Sources: notion.com/{pricing,help/sharing-and-permissions,help/use-pages-offline}, developers.notion.com/page/changelog, github.com/outline/outline/releases, getoutline.com/{changelog,pricing}, releasebot.io/updates/docmost, docmost.com/{docs,pricing}, affine.pro/pricing, appflowy.com/pricing, bookstackapp.com/blog/, support.atlassian.com/confluence-cloud/docs/view-analytics-to-see-how-content-is-performing/, gitbook.com/{docs/changelog,pricing}, slab.com/pricing/, obsidian.md/{pricing,help/Obsidian+Sync/Version+history}.

15 highest-value gaps for a solo owner on free tiers (with recommendation)

1 **Verified / owner / review-by** (Slab on free plan: primary verifier, review frequency, green banner with expiry, yellow once lapsed, diff since last verification; Notion: owner required, expiry date or indefinite, inbox + email at expiry, search badge). Add owner_id, verified_by, verified_at, verified_until; daily pg_cron flips to expired and inserts a notification; badge, filter, "changed since verified" diff. 2 **Trust-weighted search and ask-the-docs** (Notion ranks verified pages higher, notion.com/releases/2025-03-26): rank boost in FTS; mark each cited quote verified/unverified; allow "verified documents only". 3 **Real notification inbox** (2.29): one `notifications` table (AI edit waiting, verification due, mention, role change) over Realtime; skip the email digest. 4 **Request access + a `restricted` flag** instead of full per-page ACLs (Outline added "Request access" 2026-06-01): keep org/project

roles; one boolean per document; button creates a notification. 5 **Share-link hardening**: the `#/s/` payload must contain no editor ids or emails; last_viewed and view count per link; extend the anon SQL matrix to the share route. 6 **Page view analytics**: `doc_view_daily(doc_id, day, count)` upsert RPC, no per-view rows; 30-day views, last viewed, "unread 90 days" as staleness signal. 7 **Revision attribution, retention, provenance** (Notion 2026-10-13, Outline v1.10/v1.11 reasons): `revisions.actor_kind` (human | ai-token | import) with the token name; keep last N plus every verified; optional reason on delete. 8 **Per-token usage panel** + `report_issue` **MCP tool** (GitBook Agents & MCP report 2026-09-22; sendFeedback 2026-07-29; Notion admin can see last used per AI tool): last used, call count, documents touched per token from the audit log; `report_issue(doc, text)` lands in the Review inbox; defer OAuth. 9 **Content-gap list** (GitBook, 2026-10-06): log every question with no verbatim quote found, with a count; top ten on the dashboard. 10 **Templates, small**: `is_template` flag, "New from template" copies the page, no variables yet. 11 **Favorites** table (user, doc); recents stay in localStorage (as the palette). 12 **Offline: read cache only** (Notion offline is per-device, no subpage/permission sync): service worker + IndexedDB of last N opened documents. 13 **Human suggestions and comment resolution**: viewers' "suggest" edits go through the Review inbox; comments carry an anchor quote and a resolved flag, no threads yet. 14 **Minimal import/export with an exit guarantee**: Markdown zip in and out + Notion export zip import; DOCX later; keep zip export working always. 15 **Search filter chips** (project, kind, verified state, owner, labels); keyword-only until the 40-question set fails.

Over-engineered for a solo owner (cut or defer)

6.7 two-person approval; 6.4 hash chain and replay (plain append-only log + CSV is enough; audit logs are Enterprise tier elsewhere); 6.3 rotation with overlap / new-client alert (keep kill switch and per-token limits); 6.5 OAuth server (Docmost makes MCP OAuth Enterprise-only; tokens suffice for one owner — but see docs/14 for client compatibility); 8.4 pgvector until FTS fails the evaluation set; 4.6 timeline/board/ICS (list view only); 5.9 attachments (Notion free caps 5 MB, Slab 10 MB; use the 1 GB bucket, images only); 2.23/Q11 move project across organizations (export/import covers it); 2.25 chords, 2.27 visual-regression screenshots, 2.28 logos/accents; 9.10 domain + Resend until you invite more than a few people; 8.5 listen/focus/split view; 5.8 four importers at once (start with Markdown zip); 9.3 backup encryption until backups leave a private repo.

Mistakes and risks other products hit

- Public pages leaking editor identity: April 2026 reports say public Notion pages expose editors' names/emails via an unauthenticated API (cyberinsider.com/notion-pages-have-leaked-user-data-via-an-unauthenticated-api-since-2022/; secondary, fix status UNVERIFIED).
- AI edits taking effect before approval (PromptArmor: promptarmor.com/resources/notion-ai-unpatched-data-exfiltration; simonwillison.net/2025/Sep/19/notion-lethal-trifecta): our Review inbox is the right design; a pending diff must never auto-load remote images or links.
- BookStack 2026 security releases are almost all permission leaks (drafts, attachments, comments on recycled pages via API, hidden content in Markdown exports, search showing drafts): extend the RLS matrix to drafts, trash, attachments, exports, search, comments.
- Atlassian April 2022 outage (a script with wrong ids deleted ~400 customers' sites; fix = universal soft delete; atlassian.com/blog/how-we-build/post-incident-review-april-2022-outage): keep soft delete and add a TESTED restore from backup.
- Obsidian Sync silent overwrites (forum.obsidian.md/t/obsidian-sync-on-iphone-overwrites-newer-data-causing-data-loss/85214; anecdotes): keep both versions on conflict; no offline writes in v1.
- Confluence "Verified" cleared by any edit, no timestamp (CONFCLOUD-84852): store verified_at and decide explicitly what an edit does. Rubber-stamp risk: do not accept a bare "still accurate" button (Slab shows a diff since last verification).

- Vendor comparison pages can be wrong (one said Slab has no verification; Slab's own pricing lists it on free): trust first-party pages.
- Notion API churn (2026-03-11 `archived` -> `in_trash`; 2026-07-15 page links moved to app.notion.com; per-workspace rate limit 2026-06-16; notion-search keyword-only 2026-09-02): version our MCP tool schemas and key `[[kind:slug]]` links on ids. AI pricing shifts (AI bundled into Business at $20/member): keep AI off the free path, bring-your-own key.
- Supabase free pause: see docs/16. Not checked: Outline mobile, AFFiNE and Anytype 2026 changelogs, Docmost/AppFlowy permission details beyond citations, Confluence native expiry.

Audit of the ChatGPT Deep Research report, Parts A + B (2026-10-22)

Raw report: `19a-RESEARCH-AB-CHATGPT-RAW.md` (14.6k words). Audited by Claude against registries, Supabase docs and the live project. Verdict: strong report, usable, but it did not see our code or live schema and has the errors below.

Verified TRUE (primary source)

- Supabase Data API: opt-out setting 2026-04-28; default for new projects 2026-05-30; all existing projects 2026-10-30. Existing objects keep grants. Official opt-in SQL covers tables, sequences AND functions (docs "Securing your API"): `alter default privileges for role postgres in schema public revoke select,insert,update,delete on tables from anon,authenticated,service_role;` + `revoke execute on functions from anon,authenticated,service_role;` + `revoke usage,select on sequences ...;` + `revoke execute on functions from public;`. Dashboard setting: Integrations > Data API > "Default privileges for new entities". Docs also recommend a dedicated `api` schema as an extra boundary.
- React 19.3 (2026-09-09): View Transitions + Fragment refs stable; 19.3.1 on 2026-10-14. Vite 8 uses Rolldown as the single bundler, Node 20.19+/22.12+. MADR 4.0.0 = 2024-09-17. Anchor positioning: webstatus "limited" (Safari 27 available 2026-09-14), keep as enhancement only.
- GitHub Actions: standard runners free for public repos; private Free plan 2,000 min/month, 500 MB artifacts, 10 GB cache.

WRONG in the report

- "Supabase Free has managed DB backups": FALSE. Supabase backups doc: daily backups only for Pro/Team/Enterprise; Free should export its own data (`db dump`). Master plan was right.
- Version ledger: merge is 6.12.3 (report 6.12.2, called the PDF stale: the PDF was right); react 19.3.1 (not 19.3.0); zustand 5.0.16 (published 2026-10-22); react-aria-components 1.22.1.
- Missed: functions default privileges (see above). Missed our repo state: already Vite 8.3.4, TS 7.0.2, plugin-react 6, React 18.3.1; browser/invite/MCP already use publishable/secret keys (MCP reads SUPABASE_SECRET_KEYS, falls back to SERVICE_ROLE var).
- SQL pitfalls in its samples: pgcrypto lives in schema `extensions`, so `digest()` must be `extensions.digest()` under `search_path=''`; unique INDEX on (project_id,parent_id,order_key) cannot be deferred so a reorder/renumber UPDATE can hit transient duplicate errors (needs deferrable constraint or two-step renumber; not tested); sample schemas assume names that differ from ours (ours: docs.body not body_md, doc_revisions.rev not revision_no, docs.position integer, docs.parent_ref, private.can_read_project/can_edit_project already exist).

Live facts (checked 2026-10-22)

PG 17.11; DB size 15 MB of 500 MB (largest table 296 kB); unaccent available; 33 public tables all RLS on; 42 definer functions in public, 28 executable by authenticated (lint 0029), 0 by anon; 35 functions in private schema. anon has SELECT grant but no anon policy on workbench_state, app_admins, project_members (harmless, revoke for least privilege). Public anon reads (docs/doc_revisions/projects) go through private.can_read_project (built-in project is public by design).

Owner decisions raised

1. Canvas single-file build uses React 18; upgrading to 19 may break Canvas. Keep Canvas or drop it?
2. Report says use native